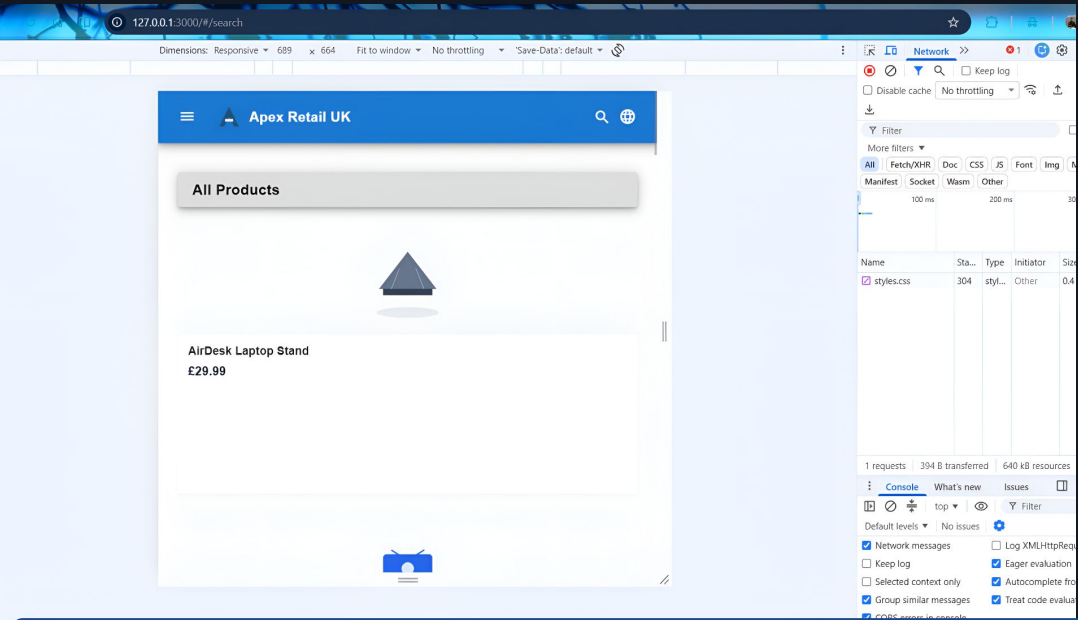


01 Board Decision & Financial Exposure

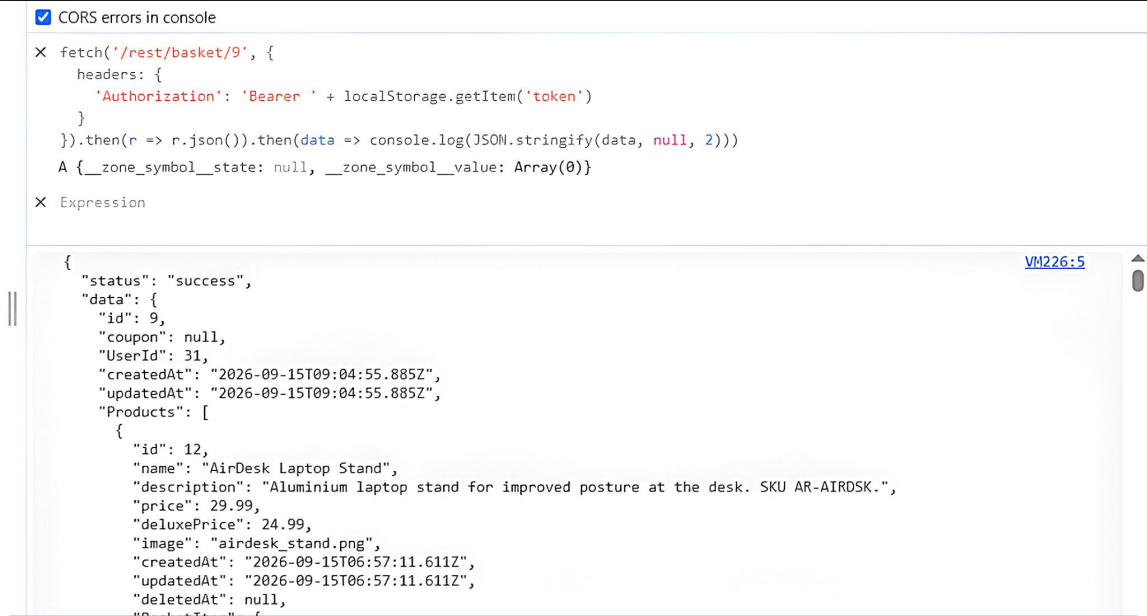
- ▶ Board Decision: Requesting immediate approval for a **£60,000** Year-1 investment to remediate Broken Object Level Authorization (BOLA) across API endpoints
- ▶ Business Context: Untreated API vulnerabilities expose customer basket and PII data, creating active financial, legal, and operational exposure for Apex Retail UK.
- ▶ Financial Exposure: (BASE CHALLENGE MODEL)
 - Single Breach Exposure: **£900,000**
 - Expected Annual Loss: **£225,000**
 - Residual Risk (Mitigated 3%): **£27,000**
 - Net Risk Reduction: **£198,000** | Year-1 ROSI: 230%
- ▶ Note: fictional Challenge assumptions — not industry benchmarks
- ▶ Source: Board Fact Pack / ROSI worksheet

02 Technical Evidence

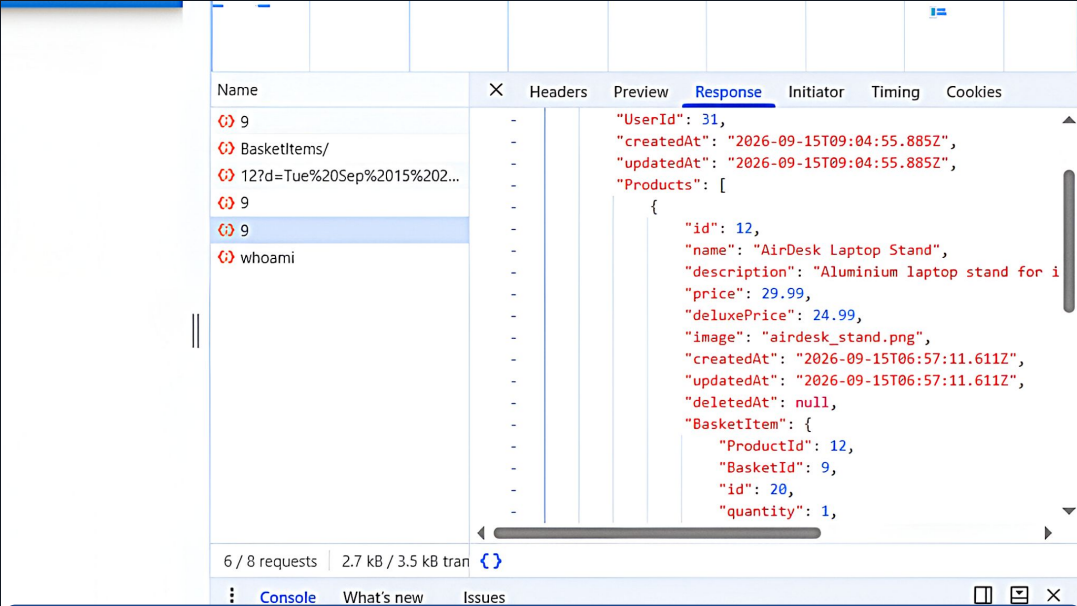
- **Summary of Finding:** Controlled testing confirmed an active Broken Object Level Authorization (BOLA) flaw allowing unauthorized access to customer cart data.
- **Baseline Access (E02):** User A (user_a@apex.local) requested and viewed their own active basket (Basket ID 9).
- **Authorization Test (E03):** User B (user_b@apex.local) requested User A's basket (Basket ID 9) and received full access to the items and user mapping (UserId: 31).
- **Technical Root Cause:** Missing server-side ownership validation prior to returning customer records.
- **Scope & Confidence:** Confirms an active system vulnerability; does not confirm historical data exfiltration by third parties.



E01



E03 (user B)



E02 (user A)

03 Blast Radius & Regulatory Assessment

- ▶ **PLAUSIBLE EXPOSURE:** 180,000 active customer accounts and 250,000 annual orders fall within the exposure boundary. Our controlled test confirmed basket contents including product details, pricing and UserId are accessible across accounts.
UNKNOWN: whether unauthorized access occurred historically outside this test, full scope of affected endpoints, and whether data left the organisation.
- ▶ **Data categories at risk:** Customer name, email address, postal address, order details, product history, invoice metadata and customer identifiers as defined in the Apex Retail UK Board Fact Pack. The platform does not store card numbers, plaintext passwords or national identity numbers in this scenario.
- ▶ **Regulatory assessment:** A vulnerability is confirmed, server-side authorization failure observed in E03. Whether a personal-data breach has occurred requires further investigation. These are distinct determinations and cannot be conflated without evidence.
- ▶ **UK GDPR framing:** The 72-hour ICO notification clock does not start on a vulnerability alone — it begins only if a personal-data breach is confirmed and likely to risk individuals' rights and freedoms. The statutory maximum of £17.5m or 4% of £52m turnover (£2.08m) is a ceiling — not an expected or automatic fine.
- ▶ Source: UK Regulatory Reference Note v1.0 | ICO breach guidance (ico.org.uk) | Board Fact Pack v1.0 | This is not legal advice.

04 Remediation, Validation & Business Case

► **ROOT CAUSE:** The server validates that a request carries an authentication token but does not verify whether the token holder owns the requested resource. Any authenticated customer can request any basket ID and receive full data. Front-end hiding is not a fix — the API endpoint remains unprotected regardless of what the UI shows.

► **PRIMARY CONTROL — Server-side ownership check:** On every GET /rest/basket/:id request, the server must compare the authenticated UserId against the basket's UserId. If they do not match, return HTTP 403 Forbidden. This check must live server-side — it cannot be delegate

DEFENCE-IN-DEPTH: Non-sequential basket IDs (UUIDs) reduce enumeration risk but are not a substitute for ownership verification. Rate limiting on resource endpoints and anomaly detection for cross-account access patterns provide additional layers. to the client.

► **VALIDATION PRINCIPLE:**

user_a@apex.local → GET /rest/basket/9 → ALLOW (owns resource)

user_b@apex.local → GET /rest/basket/9 → DENY — HTTP 403 (does not own resource)

Include this as a mandatory negative authorization test in every deployment pipeline

► **YEAR-1 BUSINESS CASE (BASE SCENARIO):** Expected loss before remediation: £225,000. Expected loss after: £27,000. Risk reduction: £198,000. Year-1 investment: £60,000. ROSI: 230%. Every £1 invested avoids £2.30 in expected loss. Investment is justified.

► **BOARD ASK:** Approve £60,000 Year-1 remediation programme. Mandate server-side authorization regression testing on every deployment. Initiate UK GDPR notification assessment. Schedule annual access-control review.